

Security Compliance: 10 Regulations and 4 Tips for Success

What is Security Compliance Management?

Security Compliance Management is an ongoing process of defining security policies, auditing compliance in line with those policies, and ensuring that compliance violations are resolved. Compliance violations must be managed according to policies developed for the specific organization.

A compliance management system is implemented by organizations to manage the entire compliance process. This includes independent testing of the organization's audit compliance capabilities, its ability to comply with its own policies and procedures, and its ability to comply with external regulations and standards.

Why is Security Compliance Important?

Compliance is important for many reasons, including trust, reputation, security, and data integrity. It can also impact a company's bottom line.

According to the recent [Ponemon Institute Cost of Data Breach Report](#), compliance is the number one factor in the cost of a data breach. Non-compliant organizations found that the average cost of a data breach was \$2.3 million higher than that of compliant organizations. The average cost of a compliance-related data breach was \$5.65 million.

The reason that non-compliance leads to higher costs is that compliance violations can result in fines and lawsuits, as well as indirect reputational damage. Organizations in highly regulated industries such as healthcare, energy and finance, tend to experience these additional costs even years after the original breach.

10 Security Compliance Laws and Standards You Should Know

1. GDPR

The European Union enacted the General Data Protection Regulation (GDPR) in 2018. This regulation sets standards for organizations that process personal data of EU residents. The GDPR applies not only to European companies, but to any organization that processes data belonging to EU citizens.

GDPR requires businesses to process personal data in a manner that prevents unauthorized data collection, processing, loss, or damage. The penalty for not doing this can be up to 4% of annual revenue or 20 million Euro, whichever is higher.

2. CCPA and CPRA

The California Consumer Privacy Act (CCPA) applies to organizations with revenues of \$25 million or more, or organizations with data belonging to over 50,000 individuals. Under this law, all California residents have the right to view any personal data stored by a company and any third parties with whom the company shares this data. Consumers have the right to sue companies if they believe their data violates the CCPA. Failure to comply with the CCPA may result in lawsuits and fines.

Like GDPR, CCPA applies to any organization that does business with California citizens. Therefore, even if your organization is not in California and does not have a physical presence there, it might be covered by the CCPA.

California voters recently passed an update to the CCPA called the California Privacy Act (CPRA), which will go into effect in early 2023. CPRA extends CCPA to make certain aspects more restrictive, but excludes small businesses from its jurisdiction. Specific changes CPRA introduces, compared to CCPA, include prohibiting businesses from retaining customer data longer than necessary and expanding the right of customers to object to data collection.

Learn more in our detailed guide to CCPA (coming soon)

3. SOC

SOC compliance certifies that a service organization has completed third-party audits and implements certain security controls. There are several levels of compliance known as SOC 1, SOC 2, and SOC 3.

SOC compliance is designed to demonstrate to a service provider's customers that the company is capable of providing contracted services. In most cases, enterprise customers are unaware of the details of their environment, making it difficult to trust that enterprises are adequately protecting sensitive data. SOC audits can verify a service provider's controls and systems to provide the necessary services.

Unlike other compliance regulations, SOC compliance is voluntary, and is not required in certain industries. The trigger for complying with SOC is usually a requirement by the organization's customers.

4. HIPAA

The US Health Insurance Portability and Accountability Act (HIPAA) requires healthcare providers to ensure that digital health information is kept confidential and secure when it is stored or transmitted. In addition, health care providers must make reasonable efforts to prevent threats, security breaches, and improper use of health data.

Failure to comply with HIPAA can result in fines of up to \$50,000 per violation or \$1.5 million per year. Some HIPAA violations can result in up to 10 years in prison.

5. FISMA

The Federal Information Security Administration Act (FISMA) regulates US Federal systems to protect information, operations, and assets that have significance for the US economy and national security. Published in 2002, it is a broad framework for managing and implementing risk management governance for government agencies and business stakeholders.

FISMA defines minimum security requirements to maintain protection from threats to government agencies. This Act is consistent with existing laws, executive orders, and guidelines for addressing cybersecurity compliance by information security programs.

The scope of the framework includes conducting an inventory of information systems, maintaining system security plans and controls, conducting risk assessments, and ensuring continuous monitoring.

6. PCI DSS

The Payment Card Industry Data Security Standard (PCI DSS) is a non-governmental information security requirement focused on protecting credit cardholder data. The standard is administered by major credit card providers and the PCI Security Standards Committee. Its main goal is to protect cardholder data.

The PCI DSS standard applies to merchants that process payment information, regardless of the number of monthly transactions or credit card transactions. Business owners must comply with 12 requirements, including firewall configuration, password protection, data encryption, restricting access to credit card information, and developing and maintaining security policies.

Businesses that do not comply can lose their merchant licenses, which means they won't be able to accept credit card payments for several years. In addition, companies that do not comply with PCI DSS can be a potential target for cyberattacks, reputational damage, and ultimately, large regulatory fines.

7. ISO/IEC 27001

ISO/IEC 27001 is an international standard for implementing and managing Information Security Management Systems (ISMS). It is published as part of the International Organization for Standardization (ISO) and International Electrotechnical Commission (IEC) 27000 series of standards.

“Business accreditation” for the ISO27001 standard means that an organization is compliant at all levels of its technological environment, including people, processes, tools and systems, and ensures the integrity and protection of customer personal data. This standard ensures there are stringent operational behaviors and practices for building a resilient and reliable cybersecurity management system.

Learn more in our detailed guide to ISO 27001 (coming soon)

8. ARPA

The Australian Prudential Regulatory Authority (APRA) is the legal body of the Australian Government and the prudential regulator of the Australian financial services industry. APRA currently oversees AUD 7.6 trillion in assets for Australian savers, policyholders and pension fund members.

ARPA oversees banks, credit unions, housing associations, associations, property and casualty insurance, health insurance, reinsurance, life insurance companies, and most companies of the pension industry. Its main goal is to ensure these institutions meet their financial commitments—ensuring they are financially sound and able to meet their obligations to savers, fund members and policyholders.

9. FedRAMP

The Federal Risk and Entitlement Management Program (FedRAMP) is a US federal government program that provides a standardized approach to security assessment, authorization, and continuous monitoring of cloud products and services. Cloud Service Providers (CSPs) wishing to provide Cloud Service Offerings (CSOs) to the US government must demonstrate FedRAMP compliance.

FedRAMP uses the NIST Special Publication 800 Series, and cloud service providers complete an independent security assessment by 3PAO (Third Party Assessment Organizations) to ensure approvals comply with the Federal Information Security Administration Act (FISMA).

Learn more in our detailed guide to FedRAMP (coming soon)

10. HITRUST

HITRUST stands for Health Information Trust Alliance. Founded in 2007, the alliance helps organizations, especially but not limited to healthcare organizations, effectively manage data, information risk and compliance.

HITRUST Certification allows suppliers and related organizations to demonstrate compliance with HIPAA requirements based on a standardized framework.

HITRUST provides the healthcare sector with the option to address information risk management across independent assurance assessments, to reduce and potentially eliminate the need for multiple audits. HITRUST aims to help organizations to "evaluate once, report many".

Organizations that create, access, store, or exchange sensitive information can use the HITRUST Common Security Framework (CSF) assessment as a roadmap for data security and compliance. CSF is a verifiable standard designed as a risk-based approach to organizational security, rather than a compliance-based approach. The HITRUST CSF Assurance Program combines aspects of popular security frameworks such as ISO, NIST, PCI, and HIPAA.

4 Security Compliance Best Practices

1. Develop A Risk Assessment Plan

Risk assessments should be performed across all business functions, including regulatory compliance. This is the best way to identify vulnerabilities in your IT security system and take proactive steps before a security risk arises. Knowing your weaknesses can help you make informed decisions in areas related to compliance.

Compliance includes hardening your IT infrastructure to protect sensitive customer and business data from unauthorized access. A comprehensive risk assessment can account for the security and compliance of all functions.

When implementing your risk assessment plan, consider the following:

- What type of data you have and how risky each data is

- Where to store your data
- Who has access to your information
- Assessing the health of your networks and information systems

2. Establish Effective Security Controls

Put security controls in place to help manage risk. Compliance is just a reporting function that shows that a business meets a set of requirements. To become compliant, you must actively create security controls.

Even if you are fully compliant, you are still at risk of a security breach. Ensure you have a balance between compliance and security. Areas to focus on when setting up IT security controls include:

- network access controls
- data encryption and key management
- system patch schedule maintenance
- firewall and router management
- incident response plans

3. Promote Team Communication

When teams are isolated, security compliance becomes more complex. Your IT or security team is at the forefront of cybersecurity with data breach, attack and prevention solutions. However, some part of your team may not know the details of compliance or regulatory requirements.

Similarly, compliance officers may be familiar with regulatory requirements but not with current technical capabilities. This requires teamwork and collaboration, to ensure that the best solutions are implemented to protect the best interests of the organization.

4. Utilize Security Compliance Automation Solutions

Automation is the best tool to reduce the time it takes to stay compliant. Common ways to automate security compliance include:

- Periodically generate the reports needed to demonstrate compliance or communicate the effectiveness of risk mitigation controls.
- Reduce redundant effort by answering surveys that span multiple frameworks and regulations.

- Centralize updates from frameworks and regulators instead of looking for changes manually.

There are many potential automation opportunities for IT and security departments. Examine repetitive tasks to determine if automation is possible. This can save time and make compliance processes more efficient.

How HackerOne Strengthens Security Compliance

Security compliance provides a necessary set of safeguards to minimize the impact of cybercrime. Automated tools and security solutions that focus on threat defense or post-breach remediation are not always able to apply findings effectively to improve security compliance. Proactive testing of applications by security experts adds a layer of protection that prevents exploits across your attack surface and enhances compliance processes.

Organizations can choose the methodology and frequency of pentesting by an elite team of vetted ethical hackers. Pentest as a Service (PTaaS) engagements are managed via the HackerOne platform, purpose built for collaboration, tracking and reporting to deliver better security compliance.

[Learn how HackerOne strengthens security compliance](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker? [+](#)